보안로그 분석

KOREA
코리아IT아카데미학원



class	정보보안 산업기사 취득과정 A
name	조채언

목 차

Ⅰ. 침해대응 업무에 적용되는 장비 메뉴 ····· 3

Ⅱ. Apache 로그 분석 ····· 6

Ⅲ. web-access_log 파일 분석 ····· 8

가. 공격 기법 및 성공여부 ····· 8

나. IDS 탐지 룰 ····· 10

Ⅳ. access.log, 보안로그분석.pcapng 파일 분석 ····· 11

가. 공격 기법 및 성공여부 ····· 11

나. 공격자 IP 및 공격대상자 IP 기술 ····· 11

다. slow HTTP Header Dos 공격 탐지 룰 ····· 12

Ⅴ. ELK Stack으로 SSH 접속 실패 로그 시각화 ····· 13

Ⅰ. 침해대응 업무에 적용되는 장비 메뉴

1. 방화벽 (Firewall)

방화벽의 기본 역할은 신뢰 수준이 다른 네트워크 구간들 사이에 놓여서 신뢰 수준이 낮은 네트워크로부터 오는 해로운 트래픽이 신뢰 수준이 높은 네트워크로 오지 못하게 막는 것이다. 흔히 네트워크 관리자의 입장에서 높은 신뢰도를 갖는 구간은 내부 네트워크 구간이라 하고, 낮은 신뢰도를 갖는 구간은 인터넷 구간 또는 외부 네트워크 구간이라고 한다.

이 밖에도 외부에 서비스를 제공하는 서버들을 위한 DMZ구간이 있으며 인터넷으로부터 내부 네트워크로 침입을 막는 동시에 내부 네트워크에서 인터넷과 자유롭게 통신할 수 있도록 도와준다.

- **주요 기능**

① **접근 제어(Access Control)**

관리자가 방화벽에 통과시킬 접근과 그렇지 않은 접근을 명시하면, 방화벽은 이를 수행한다. 이러한 접근제어는 패킷 필터링(Packet Filtering) 방식과 상태 기반 검사(Stateful Inspection) 방식으로 나뉜다.

② **로깅과 감사 추적(Logging and Auditing)**

방화벽은 룰셋 설정과 변경, 관리자의 접근, 네트워크 트래픽의 허용 또는 차단과 관련된 사항을 로그로 남긴다.

③ **네트워크 주소 변환(NAT)**

내부 네트워크에서 사용하는 사설 IP 주소를 공인 IP 주소로 변환하여 외부로의 통신을 가능하게 하며, 내부 네트워크 구조를 외부에 숨겨 보안성을 높인다.

2. 침입 방지 시스템(IPS)

침입 방지 시스템(IPS, Intrusion Prevention System)은 네트워크 트래픽을 실시간으로 감시하여 악의적인 침입 시도를 탐지하고 즉시 차단하는 능동형 보안 장비이다. 단순히 공격을 탐지하고 알람을 울리는 데 그치지 않고, 트래픽이 통과하는 경로(In-Line)에 배치되어 위협을 실시간으로 무력화한다.

이를 통해 외부 공격자로부터 내부 시스템 및 주요 자원을 안전하게 보호하는 역할을 수행한다.

- **주요 기능**

① **심층 패킷 검사(Deep Packet Inspection)**

패킷의 헤더 정보뿐만 아니라 페이로드(Payload) 내부의 데이터까지 정밀 분석하여 숨겨진 악성 코드나 유해 트래픽을 탐지한다.

② **실시간 차단(Real-time Blocking)**

유해 트래픽이나 공격 패킷이 발견되는 즉시 해당 패킷을 드롭(Drop)시키거나 세션을 강제 종료하여 시스템 피해를 사전에 방지한다.

③ **시그니처 및 행위 기반 탐지(Signature & Behavior Detection)**

이미 알려진 공격 패턴(Signature)을 비교 검사하는 방식과, 정상 범주를 벗어난 비정상적인 트래픽 흐름(Behavior)을 감지하는 방식을 혼용하여 탐지한다.

3. 웹 방화벽(WAF)

웹 방화벽(WAF, Web Application Firewall)은 웹 애플리케이션 계층(HTTP/HTTPS)에서 발생하는 공격을 전문적으로 탐지하고 차단하는 보안 솔루션이다. 일반 방화벽이나 IPS가 검사하기 어려운 웹 특화 공격을 전담하여 방어한다.

웹 서버 전면에 위치하여 웹 서비스 이용자와 서버 간의 모든 트래픽을 중계하고 검증함으로써 웹 애플리케이션의 취약점을 노린 공격을 효과적으로 차단한다.

- 주요 기능

① 웹 취약점 공격 차단(OWASP Top 10 Defense)

SQL Injection, XSS(Cross-Site Scripting), Command Injection 등 웹 서비스의 대표적인 취약점을 노린 공격을 분석하고 차단한다.

② 암호화 트래픽 복호화 검사(SSL/TLS Decryption)

HTTPS로 암호화되어 전달되는 트래픽을 실시간으로 복호화하여 패킷 내부의 악성 웹 요청이나 웹쉘 업로드 시도를 검사한다.

③ 가상 패치(Virtual Patching)

웹 애플리케이션의 소스 코드 수정이 즉시 불가능한 경우, 웹 방화벽 수준에서 해당 취약점으로 들어오는 공격 패턴을 미리 차단하여 소스 코드 패치 전까지의 보안 공백을 메운다.

4. 통합 로그 관리 시스템(SIEM)

SIEM(Security Information and Event Management)은 조직 내의 방화벽, IPS, WAF, 서버 등 이기종 시스템에서 발생하는 방대한 보안 로그와 이벤트를 한곳으로 수집하여 통합 분석하는 시스템이다.

개별 장비에서는 단편적인 이벤트로 보이는 정보들을 종합적으로 연관 분석하여 지능형 위협 및 내부 침해사고를 빠르게 감지하도록 돕는다.

- 주요 기능

① 이기종 로그 수집 및 정규화(Log Collection & Normalization)

서로 다른 포맷으로 출력되는 다양한 장비들의 로그 데이터를 하나의 표준 규격으로 정규화하여 저장하고 관리한다.

② 연관 분석(Correlation Analysis)

여러 보안 장비에서 시차를 두고 발생한 단편적인 이벤트들을 하나의 공격 시나리오로 묶어 복합적인 침해 시도를 실시간 탐지한다.

③ 타임라인 추적 및 리포팅(Timeline Tracking & Reporting)

침해사고 발생 시 공격자의 최초 침입 시점부터 내부 전파 과정까지의 행적을 시간순으로 추적할 수 있도록 시각화된 데이터와 감사 보고서를 제공한다.

5. 엔드포인트 탐지 및 대응(EDR)

EDR(Endpoint Detection and Response)은 사용자 PC나 서버 등 엔드포인트 단말 내부에서 발생하는 모든 행위를 실시간으로 모니터링하고 분석하는 보안 솔루션이다.

네트워크 보안 장비를 우회하여 단말 내부로 들어온 신종 악성코드나 암호화 공격(랜섬웨어)을 탐지하고, 감염 시 즉각적인 대응 작업을 수행한다.

- 주요 기능

① 단말 행위 기반 모니터링(Behavior Monitoring)

단말 내 프로세스 실행, 파일 생성 및 수정, 레지스트리 변형 등의 상세 행위 이력을 실시간으로 수집하고 분석한다.

② 실시간 네트워크 격리(Host Isolation)

악성코드 감염이나 침해 정황이 포착된 해당 단말을 네트워크상에서 즉시 물리적/논리적으로 격리하여 내부 네트워크로의 확산을 방지한다.

③ 실시간 치료 및 원상 복구(Remediation & Rollback)

탐지된 악성 프로세스를 즉시 종료하고 관련 파일을 삭제하며, 랜섬웨어 등으로 인해 훼손된 데이터는 백업본(섀도 복사본 등)을 이용해 변경 전 상태로 복원한다.

Ⅱ. Apache 로그 분석

- 로그 원문

```
192.168.123.123 - - [28/May/2022:06:22:38 +0000] "GET /gnuboard/ HTTP/1.1" 200 867 "http://192.168.123.222/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/101.0.4951.64 Safari/537.36"
```

로그 항목	값	의미
Client IP	192.168.123.123	웹 서버에 접속을 요청한 클라이언트(사용자)의 IP 주소이다. 침해사고 발생 시 공격자 또는 접속자를 식별하는 가장 중요한 정보이며, 동일 IP의 반복 접속 여부와 공격 경로를 분석하는 데 활용된다. 또한 방화벽, IDS/IPS, SIEM 등의 로그와 연계하여 공격자의 행위를 추적할 수 있다.
ident	-	RFC 1413(Ident Protocol)을 통해 클라이언트의 사용자 정보를 조회하는 필드이다. 대부분의 Apache 서버에서는 보안 및 성능상의 이유로 비활성화되어 있으므로 '-'로 표시된다.
AuthUser	-	HTTP Basic 또는 Digest 인증을 통해 로그인한 사용자 계정을 기록하는 항목이다. 인증이 수행되지 않은 일반 페이지 접근이므로 '-'로 표시된다.
접속 시간	28/May/2022:06:22:38 +0000	웹 서버가 요청을 수신한 시간이다. 2022년 5월 28일 06시 22분 38초(UTC)를 의미하며, 침해사고 분석 시 여러 장비의 로그를 시간순으로 비교하여 공격 발생 시점을 확인하는 기준이 된다.
요청 방식 (Method)	GET /gnuboard/ HTTP/1.1	클라이언트가 서버에 보낸 HTTP 요청이다. GET은 웹 페이지를 조회하는 요청 방식이며 서버의 데이터를 변경하지 않는다. **/gnuboard/**는 GNUBoard 게시판의 메인 디렉터리를 요청한 것이고, HTTP/1.1은 사용된 HTTP 프로토콜 버전이다.
상태 코드	200	서버가 요청을 정상적으로 처리했음을 의미하는 성공(OK) 상태코드이다. 요청한 페이지가 정상적으로 전송되었음을 나타낸다. 다만 200 코드는 공격자가 취약한 페이지에 정상적으로 접근했을 때도 기록될 수 있으므로 요청 URL과 함께 분석해야 한다.

응답 크기	867	서버가 클라이언트에게 전송한 실제 콘텐츠(Body)의 크기이며 867Byte이다. 응답 크기를 통해 정상 페이지인지, 오류 페이지인지 또는 대용량 파일 전송 여부 등을 판단하는 참고 자료로 활용된다.
Referer	http://192.168.123.222/	사용자가 현재 페이지에 접속하기 전에 방문했던 웹 페이지를 의미한다. 즉, 192.168.123.222 페이지에서 링크 또는 리다이렉트를 통해 /gnuboard/ 페이지로 이동한 것으로 해석된다. 침해사고 대응에서는 악성 사이트를 통한 유입 여부를 확인하는 데 활용된다.
User-Agent	Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/101.0.4951.64 Safari/537.36	클라이언트의 운영체제와 웹 브라우저 정보를 나타낸다. 운영체제는 macOS Catalina 10.15.7, 브라우저는 Google Chrome 101.0.4951.64이며, AppleWebKit 537.36 렌더링 엔진을 사용한다. User-Agent는 정상 사용자와 자동화 공격 도구(sqlmap, nikto, curl 등)를 구분하거나 브라우저 위장 여부를 분석하는 데 활용된다.

- **종합 분석**

2022년 5월 28일 06시 22분 38초(UTC 기준)에 IP 주소가 192.168.123.123인 사용자가 macOS (Intel Mac OS X 10_15_7) 환경의 Chrome 101 브라우저를 이용하여 http://192.168.123.222/ 페이지를 거쳐 GNUBoard 메인 페이지 (/gnuboard/)를 GET 방식으로 접속 요청한 기록이다. 서버는 요청을 정상적으로 처리하여 HTTP 200 OK 상태코드와 867Byte의 데이터 페이지를 정상적으로 응답·전송한 로그이다. Referer 정보를 보면 사용자는 192.168.123.222 페이지에서 링크를 통해 접근한 것으로 추정된다.

Ⅲ. web-access_log 파일 분석

가. 공격 기법 및 성공여부

시간	공격 기법	로그 내용	성공 여부	분석
10:55:10	DVWA 접속	GET /DVWA/index.php → 302 GET /DVWA/login.php → 200	-	DVWA 웹 애플리케이션에 최초 접속하였으며, 로그인 페이지로 이동하였다.
10:55:16	로그인 성공	POST /DVWA/login.php → 302 GET /DVWA/index.php → 200	성공	정상적으로 인증에 성공하여 DVWA 메인 페이지에 접근하였다.
10:55:39	LFI 공격 시작	GET /DVWA/vulnerabilities/fi/?page=include.php	성공	파일 포함(Local File Inclusion) 취약점 페이지에 접근하여 공격을 준비하였다.
10:56:03	Security Level 변경	POST /DVWA/security.php → 302	-	DVWA의 Security Level을 변경하여 취약점을 쉽게 공격할 수 있도록 설정을 변경하였다.
10:56:16	/etc/passwd 파일 읽기	GET /DVWA/vulnerabilities/fi/?page=../../../../../../etc/passwd → 200 (5944Byte)	성공	디렉터리 트래버설을 이용해 리눅스의 /etc/passwd 파일을 성공적으로 조회하였다. LFI 공격이 성공한 것으로 판단된다.
10:57:16	SQL Injection	GET/DVWA/vulnerabilities/sqli/?id=' or 1=1#	성공	' OR 1=1# 구문을 삽입하여 인증 우회 또는 데이터 조회를 시도하는 SQL Injection 공격을 수행하였다.
10:58:20	XSS 공격	GET /DVWA/vulnerabilities/xss_d/?default=<script>alert('XSS') </script>	성공	JavaScript를 삽입하여 DOM 기반 XSS 취약점 존재 여부를 확인하였다.
10:59:11	세션 종료	/etc/passwd 요청 후 302 → login.php	-	인증 세션이 만료되어 로그인 페이지로 리다이렉트되었으며, 추가 공격을 위해 재로그인이 필요한 상태가 되었다.
11:05:18	재접속	GET /, GET /DVWA	성공	일정 시간이 지난 후 DVWA 서버에 다시 접속하였다.

11:05:25	Security Level 재설정	POST /DVWA/security.php	-	Brute Force 공격 수행 전 Security Level을 다시 변경하였다.
11:05:28	Command Injection 페이지 접근	GET /DVWA/ vulnerabilities/exec/	실패	명령 실행(Command Injection) 취약점 페이지에 접근하였으나 실제 명령 실행 요청은 확인되지 않았다.
11:05:31	CSRF 페이지 접근	GET /DVWA/ vulnerabilities/csrf/	실패	CSRF 취약점 페이지에 접근하였으나 실제 공격 요청은 발생하지 않았다.
11:05:34 ~ 11:07:16	Brute Force 공격 수행	/vulnerabilities/brute/ ?username= ...&password= ... 반복 요청	실패	admin, administrator, user, test 등 여러 계정과 1234, password, test 등의 비밀번호를 반복적으로 시도하여 계정 탈취를 위한 무차별 대입(Brute Force) 공격을 수행하였다.

나. IDS 탐지 룰

1. LFI 탐지 룰

```
alert tcp any any -> $HTTP_SERVERS $HTTP_PORTS (msg:"LFI ../ access"; flow:to_server, established; content:"GET"; http_method; content:"../"; http_uri; priority:2; sid:2026080701; rev:1;)
alert tcp any any -> $HTTP_SERVERS $HTTP_PORTS (msg:"LFI /etc/passwd access"; flow:to_server,established; content:"/etc/passwd"; http_uri; nocase; priority:1; sid:2026080702; rev:1;)
```

첫 번째 룰 - 상위 디렉터리 이동(../) 패턴 탐지 룰

웹 애플리케이션의 파일 인클루드 취약점을 노리고, 상위 디렉터리로 이동하는 대표적인 경로 이탈 패턴인 ../ 문자열을 탐지하기 위한 룰이다. TCP 연결이 정상적으로 확립된 상태에서 외부 클라이언트가 웹 서버로 보내면 HTTP GET 요청의 URI 내에 상위 폴더 접근을 의미하는 ../ 패턴이 포함되어 있는지 검사해 탐지 시 경고를 발생시킨다.

두 번째 룰 - 시스템 주요 파일(/etc/passwd) 접근 탐지 룰

LFI 취약점을 악용하여 리눅스 시스템의 사용자 계정 정보가 담긴 핵심 파일인 /etc/passwd에 직접 접근하려는 고위험 공격 행위를 탐지하기 위한 룰이다. HTTP 요청 URI 내에 /etc/passwd 경로가 포함되어 있는지 검사한다. 특히 대소문자를 구분하지 않는 옵션을 적용하여 대소문자 변형을 통한 IDS 우회 시도까지 함께 탐지하도록 구성되어 있다. 공격자가 LFI 취약점의 존재 여부를 검증하거나 실제 민간/시스템 정보를 탈취하려는 명확한 악의적 시도를 탐지하는 룰로, 즉각적인 대응이 필요한 높은 위험도 이벤트로 분류된다.

2. SQL Injection 탐지 룰

```
alert tcp any any -> $HTTP_SERVERS $HTTP_PORTS (msg:"EXPLOIT-WEB-KIT SQL Injection Attempt - Tautology Pattern"; flow:to_server,established; content:"' OR "; http_uri; nocase; priority:1; sid:2026080703; rev:1;)
```

인증 우회(Tautology) SQL Injection 탐지 룰

로그인 페이지나 인증 로직에서 항상 참(True)이 되는 조건문(' OR '1'='1 등)을 삽입하여, 패스워드 검증 절차를 우회하고 무단 로그인을 시도하는 행위를 탐지하기 위한 룰이다. HTTP 요청 URI 내에 SQL 조건절을 강제로 참으로 만들기 위해 자주 사용되는 특수문자와 논리 연산자 패턴(' OR)이 포함되어 있는지 검사해 대소문자 구분이 없는 환경에서도 우회할 수 없도록 필터링한다. 시스템 권한 탈취 및 비인증 접근을 목적으로 하는 웹 취약점 스캔 및 공격 시도를 실시간으로 차단·경고하기 위한 필수적인 탐지 규칙이다.

IV. access.log, 보안로그분석.pcapng 파일 분석

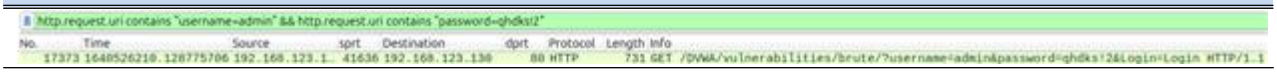
가. 공격 기법 및 성공여부

1. 응답 크기 변화를 통한 브루트포스 공격 성공 확인



브루트포스 공격 과정에서 대부분의 로그인 요청은 동일한 응답 크기(4241 Byte)를 반환하였으나, 1개의 요청만 응답 크기가 4244 Byte로 다르게 나타났다. 이는 올바른 계정 정보로 로그인에 성공하면서 서버가 다른 응답 페이지를 반환한 것으로, 브루트포스 공격 성공을 확인할 수 있는 근거가 된다.

2. 로그인 성공 요청 확인



HTTP 요청을 분석한 결과 username=admin과 password=qhdks!2를 포함한 로그인 요청이 확인되었다. 해당 요청은 이후 로그인 성공 페이지를 반환한 요청으로, 정상 인증이 이루어진 것을 확인할 수 있다.

3. 로그인 성공 페이지 확인



서버 응답에 "Welcome to the password protected area admin" 메시지가 포함되어 있으며, 보호된 페이지가 정상적으로 표시되었다. 이를 통해 admin 계정을 이용한 로그인에 성공했음을 최종 확인하였다.

나. 공격자 IP 및 공격대상자 IP 기술

- **공격자 IP :** 192.168.123.129
- **공격 대상 IP :** 192.168.123.130
- **공격 기법 :** Brute Force
- **기술 :** 공격자는 192.168.123.129에서 192.168.123.130의 DVWA 웹 서버 로그인 페이지를 대상으로 Brute Force 공격을 수행하였다. 반복적인 인증 요청을 통해 관리자 계정(admin)의 로그인에 성공하였으며, 이후 보호된 관리자 페이지에 접근한 것을 확인하였다.

다. slow HTTP Header Dos 공격 탐지 룰

```
alert tcp any any -> 80
(msg:"";flow:to_server,established;pcre:"/[^₩x0d₩x0a]₩x0d₩x0a$/";threshold:type both,
track by_src,count 10,seconds 2;sid:202201010101;)
```

이 룰은 짧은 시간 동안 HTTP 요청을 반복적으로 보내는 Brute Force 공격을 탐지하기 위한 Snort 룰이다. 웹 서버의 80번(HTTP) 포트로 전송되는 TCP 트래픽을 모니터링하며, 연결이 정상적으로 수립된 상태에서 서버로 전달되는 HTTP 요청만을 분석 대상으로 한다. HTTP 요청이 정상적인 형식임을 확인한 후, 동일한 출발지 IP에서 2초 동안 10회 이상의 요청이 발생할 경우 Brute Force 공격으로 판단하여 경고를 생성한다. 이러한 임계값(Threshold) 기반 탐지 방식을 통해 짧은 시간 내 반복적인 로그인 시도를 식별할 수 있으며, 관리자 계정 탈취를 목적으로 수행되는 무차별 대입 공격을 신속하게 탐지할 수 있다.

V. ELK Stack으로 SSH 접속 실패 로그 시각화

Rocky에서 작업

1. Elastic 저장소 생성

```
root@roror:/home/roror# cd /etc/yum.repos.d
root@roror:/etc/yum.repos.d# ls
docker-ce.repo  epel.repo          rocky-addons.repo  rocky-extras.repo  rocky-security.repo
elastic.repo    epel-testing.repo  rocky-devel.repo   rocky.repo
root@roror:/etc/yum.repos.d# vi elastic.repo

[elastic-9.x]
name=Elastic repository for 9.x packages
baseurl=https://artifacts.elastic.co/packages/9.x/yum
gpgcheck=1
enabled=1
gpgkey=https://artifacts.elastic.co/GPG-KEY-elasticsearch
type=rpm-md
```

ELK Stack 설치를 위해 Elastic 9.x 공식 YUM 저장소를 Rocky Linux에 등록하였다. 저장소를 활성화하고 GPG 서명 검증을 설정하여 신뢰할 수 있는 패키지만 설치하도록 구성하였으며, 이를 통해 Elasticsearch, Logstash, Kibana 등의 패키지를 안전하게 설치할 수 있도록 하였다.

2. GPG Key 등록

```
root@roror:/etc/yum.repos.d# rpm --import https://artifacts.elastic.co/GPG-KEY-elasticsearch
```

rpm --import 명령을 사용하여 Elastic의 공식 GPG 공개키를 시스템에 등록하였다. 이를 통해 패키지 설치 시 서명을 검증하여, 신뢰할 수 있는 Elastic 패키지만 설치할 수 있도록 구성하였다.

3. 캐시 생성

```
root@roror:/etc/yum.repos.d# dnf makecache
Docker CE Stable - x86_64                                  2.2 kB/s | 2.0 kB     00:0
Docker CE Stable - x86_64                                  133 kB/s |  24 kB     00:0
Elastic repository for 9.x packages                         21 kB/s | 1.7 kB     00:0
Extra Packages for Enterprise Linux 10 - x86_64            4.7 kB/s |  11 kB     00:0
Extra Packages for Enterprise Linux 10 - x86_64            2.1 MB/s | 6.6 MB     00:0
Rocky Linux 10 - BaseOS                                    2.0 kB/s | 4.3 kB     00:0
Rocky Linux 10 - BaseOS                                    4.1 MB/s |  14 MB     00:0
Rocky Linux 10 - BaseOS - Debug                            3.0 kB/s | 3.0 kB     00:0
Rocky Linux 10 - BaseOS - Debug                            275 kB/s | 315 kB     00:0
Rocky Linux 10 - AppStream                                 4.6 kB/s | 4.3 kB     00:0
Rocky Linux 10 - AppStream                                 1.7 MB/s | 2.4 MB     00:0
Rocky Linux 10 - Extras                                    3.1 kB/s | 3.0 kB     00:0
Rocky Linux 10 - Extras                                    5.5 kB/s | 5.8 kB     00:0
Metadata cache created.
```

dnf makecache 명령을 실행하여 등록된 YUM 저장소의 패키지 메타데이터를 최신 상태로 갱신하여 패키지 검색 및 설치 시 최신 저장소 정보를 사용할 수 있도록 구성하였다.

4. Filebeat 설치

```
root@roror:/etc/yum.repos.d# dnf install filebeat -y
Elastic repository for 9.x packages                              11 kB/s | 1.7 kB     00:00
Package filebeat-9.4.4-1.x86_64 is already installed.
Dependencies resolved.
Nothing to do.
Complete!
root@roror:/etc/yum.repos.d# filebeat version
filebeat version 9.4.4 (amd64), libbeat 9.4.4 [45b2d3821c3ff0da055e025ec16a126c27423462 built 2026-07-15 14
:56:03 +0000 UTC] (FIPS-distribution: false)
```

dnf install filebeat -y 명령을 실행하여 Elastic 저장소로부터 Filebeat 설치를 시도하였으며, filebeat-9.4.4-1.x86_64 패키지가 이미 최신 상태로 설치되어 있음을 확인하였다.

5. SSH 로그 수집 설정

```
root@roror:/etc/yum.repos.d# cd /etc/filebeat
root@roror:/etc/filebeat# vi filebeat.yml
filebeat.inputs:

# Each - is an input. Most options can be set at the input level, so
# you can use different inputs for various configurations.
# Below are the input-specific configurations.

# filestream is an input for collecting log messages from files.
- type: filestream

  # Unique ID among all inputs, an ID is required.
  id: my-filestream-id

  # Change to true to enable this input configuration.
  enabled: true

  # Paths that should be crawled and fetched. Glob based paths.
  paths:
    - /var/log/secure
    #- c:\programdata\elasticsearch\logs\*
```

filebeat.inputs 항목 내 기존 입력(filestream) 설정을 수정하여 enabled: true로 활성화하고, Rocky Linux의 SSH 보안 로그가 기록되는 경로인 /var/log/secure를 수집 대상(paths)으로 지정한다.

6. Elasticsearch 출력 비활성화 및 Logstash 출력 추가

```
#output.elasticsearch:
  # Array of hosts to connect to.
  #hosts: ["localhost:9200"]
```

```
output.logstash:
  # The Logstash hosts
  hosts: ["10.0.0.222:5044"]
```

output.elasticsearch 설정 섹션을 주석 처리하여 Elasticsearch로의 직접 전송을 비활성화하고, output.logstash 설정을 활성화하고 Logstash가 동작 중인 서버 IP(10.0.0.222:5044)를 지정하여, 수집된 로그가 Logstash로 전송되도록 출력 경로를 변경한다.

7. Elasticsearch 출력 비활성화 및 Logstash 출력 추가

```
root@roror:/home/roror# filebeat test config
Config OK
root@roror:/home/roror# filebeat test output
logstash: 10.0.0.222:5044...
  connection...
    parse host... OK
    dns lookup... OK
    addresses: 10.0.0.222
    dial up... ERROR dial tcp 10.0.0.222:5044: i/o timeout
```

filebeat test config 명령을 수행하여 수정된 문법 및 구문 오류가 없음을 확인하였고, 이어 filebeat test output 명령으로 Logstash 서버(Ubuntu)와의 연결 상태를 점검하였으나, 네트워크 통신 시도 시 타임아웃 오류가 발생하여 접속이 불가능한 상태임을 확인하였다.

Ubuntu에서 작업

8. Ubuntu Logstash 설정

```
root@elk:/home/roror# cd /etc/logstash/conf.d
root@elk:/etc/logstash/conf.d# vi ssh.conf
```

```
input {
  beats {
    port => 5044
  }
}

filter {

  # SSH 관련 로그만 처리
  if [message] !~ /(Failed password|Accepted password|Invalid user)/ {
    drop { }
  }
```

```
  # Failed password
  grok {
    match => {
      "message" => [
        "^%{SYSLOGTIMESTAMP:syslog.timestamp} %{HOSTNAME:host.name} %{DATA:process.name}\[%{NUMBER:process.pid:int}\]: Failed password for %{DATA:ssh.username} from %{IP:source.ip} port %{NUMBER:source.port:int} ssh2$",
        "^%{SYSLOGTIMESTAMP:syslog.timestamp} %{HOSTNAME:host.name} %{DATA:process.name}\[%{NUMBER:process.pid:int}\]: Failed password for invalid user %{DATA:ssh.username} from %{IP:source.ip} port %{NUMBER:source.port:int} ssh2$",
        "^%{SYSLOGTIMESTAMP:syslog.timestamp} %{HOSTNAME:host.name} %{DATA:process.name}\[%{NUMBER:process.pid:int}\]: Accepted password for %{DATA:ssh.username} from %{IP:source.ip} port %{NUMBER:source.port:int} ssh2$"
      ]
    }
  }

  # 시간 변환
  date {
    match => [
      "[syslog][timestamp]",
      "MMM dd HH:mm:ss",
      "MMM  d HH:mm:ss"
    ]
    target => "@timestamp"
  }

  # 이벤트 분류
  if "Failed password" in [message] {

    mutate {
      add_field => {
        "[event][category]" => "authentication"
        "[event][type]" => "start"
        "[event][action]" => "ssh_login_failed"
        "[event][outcome]" => "failure"
        "[network][transport]" => "tcp"
        "[service][name]" => "sshd"
        "[log][level]" => "warning"
      }

      add_tag => [
        "ssh",
```

```
        "bruteforce",
        "failed"
      ]
    }

  } else if "Accepted password" in [message] {

    mutate {
      add_field => {
        "[event][category]" => "authentication"
        "[event][type]" => "start"
        "[event][action]" => "ssh_login_success"
        "[event][outcome]" => "success"
        "[network][transport]" => "tcp"
        "[service][name]" => "sshd"
        "[log][level]" => "info"
      }

      add_tag => [
        "ssh",
        "success"
      ]
    }

  }

  # GeoIP
  geoip {
    source => "[source][ip]"
    target => "[source][geo]"
  }

  mutate {

    remove_field => [
      "@version"
    ]

  }

}

output {
```

```
elasticsearch {
    hosts => ["https://elk.roror.co.kr:9200"]
    ssl_enabled => true
    ssl_certificate_authorities => ["/etc/logstash/certs/http_ca.crt"]
    ssl_verification_mode => "full"
    user => "elastic"
    password => "qhdks12"
    index => "rocky-ssh-%{+YYYY.MM.dd}"
  }
}
```

input 및 filter 섹션을 통해 Beats(5044 포트)로 수집된 SSH 인증 로그(로그인 성공/실패, 미존재 계정 접근 시도)를 Grok 패턴으로 파싱하고 시간대 변환, 이벤트 필드 분류 및 GeoIP 태깅 작업을 수행하도록 파이프라인을 구성한다. output 섹션에서 보안 인증(SSL/TLS) 및 계정 정보를 적용하여, 가공된 SSH 로그 데이터를 Elasticsearch(https://elk.roror.co.kr:9200)의 일자별 인덱스(rocky-ssh-YYYY.MM.dd)로 전송하도록 설정한다.

9. iptables 정책 설정

```
*filter
:INPUT DROP [0:0]
:FORWARD ACCEPT [0:0]
:OUTPUT ACCEPT [66:8043]
#-A FORWARD -j NFQUEUE --queue-num 4
#-A INPUT -p icmp --icmp-type echo-request -j NFQUEUE --queue-num=4
-A INPUT -m state --state RELATED,ESTABLISHED -j ACCEPT
-A INPUT -p icmp -j ACCEPT
-A INPUT -i lo -j ACCEPT
-A INPUT -p tcp -m state --state NEW -m tcp --dport 22 -j ACCEPT
-A INPUT -p tcp -m state --state NEW -m tcp --dport 80 -j ACCEPT
-A INPUT -p tcp -m state --state NEW -m tcp --dport 443 -j ACCEPT
-A INPUT -p tcp -m state --state NEW -m tcp --dport 5601 -j ACCEPT
-A INPUT -p tcp -m state --state NEW -m tcp --dport 3128 -j ACCEPT
-A INPUT -p tcp -m state --state NEW -m tcp --dport 9200 -j ACCEPT
-A INPUT -p tcp -m state --state NEW -m tcp --dport 8080 -j ACCEPT
-A INPUT -p tcp -m state --state NEW -m tcp --dport 9300 -j ACCEPT
-A INPUT -p tcp -m state --state NEW -m tcp --dport 5044 -j ACCEPT
#-A INPUT -j REJECT --reject-with icmp-host-prohibited
#-A FORWARD -j REJECT --reject-with icmp-host-prohibited
COMMIT
```

Logstash 통신에 사용되는 TCP 5044 포트에 대한 신규 연결 허용 규칙을 추가하여 Rocky에서 Filebeat 출력 테스트 시 발생했던 통신 타임아웃 오류를 해결하고, Filebeat에서 인바운드 5044 포트를 통해 Logstash 서버로 방화벽 차단 없이 로그 데이터를 정상 전송할 수 있도록 방화벽 설정을 완료한다.

10. iptables 정책 확인

```
root@elk:/etc/logstash/conf.d# systemctl restart iptables
root@elk:/etc/logstash/conf.d# iptables -nL | grep 5044
ACCEPT     6    --  0.0.0.0/0            0.0.0.0/0           state NEW tcp dpt:5044
```

Logstash 서버의 iptables 방화벽 규칙을 수정하여 5044 포트를 허용하도록 설정한 후 서비스를 재시작하고, iptables -nL | grep 5044 명령으로 Logstash 통신용 5044 포트의 접근 허용 규칙이 정상 반영된 것을 확인한다.

11. Logstash 문법 검사

```
root@elk:/etc/logstash/conf.d# sudo -u logstash /usr/share/logstash/bin/logstash --path.settings /etc/l
ogstash -t

Configuration OK
[2026-07-31T14:07:37,331][INFO ][logstash.runner          ] Using config.test_and_exit mode. Config Val
idation Result: OK. Exiting Logstash
```

logstash 계정 권한으로 설정 파일의 문법 검사를 수행하여 검사 결과 Configuration OK 메시지를 확인하여 Logstash 설정 파일의 구문 및 설정 내용에 오류가 없음을 정상적으로 검증한다.

12. Logstash 재시작

```
root@elk:/etc/logstash/conf.d# systemctl restart logstash
root@elk:/etc/logstash/conf.d# systemctl status logstash
● logstash.service - logstash
     Loaded: loaded (/usr/lib/systemd/system/logstash.service; enabled; preset: enabled)
     Active: active (running) since Fri 2026-07-31 14:09:57 UTC; 7s ago
   Main PID: 4463 (java)
      Tasks: 41 (limit: 9367)
     Memory: 591.3M (peak: 592.1M)
        CPU: 19.578s
     CGroup: /system.slice/logstash.service
             └─4463 /usr/share/logstash/jdk/bin/java -Xms1g -Xmx1g -Djava.awt.headless=true -Dfile.enc>

Jul 31 14:10:03 elk.roror.co.kr logstash[4463]: [2026-07-31T14:10:03,851][WARN ][logstash.outputs.elas>
Jul 31 14:10:03 elk.roror.co.kr logstash[4463]: [2026-07-31T14:10:03,852][INFO ][logstash.outputs.elas>
Jul 31 14:10:03 elk.roror.co.kr logstash[4463]: [2026-07-31T14:10:03,855][INFO ][logstash.outputs.elas>
Jul 31 14:10:03 elk.roror.co.kr logstash[4463]: [2026-07-31T14:10:03,865][INFO ][logstash.outputs.elas>
Jul 31 14:10:03 elk.roror.co.kr logstash[4463]: [2026-07-31T14:10:03,866][WARN ][logstash.outputs.elas>
Jul 31 14:10:03 elk.roror.co.kr logstash[4463]: [2026-07-31T14:10:03,867][INFO ][logstash.outputs.elas>
Jul 31 14:10:03 elk.roror.co.kr logstash[4463]: [2026-07-31T14:10:03,870][INFO ][logstash.outputs.elas>
Jul 31 14:10:03 elk.roror.co.kr logstash[4463]: [2026-07-31T14:10:03,877][INFO ][logstash.outputs.elas>
Jul 31 14:10:03 elk.roror.co.kr logstash[4463]: [2026-07-31T14:10:03,878][WARN ][logstash.outputs.elas>
Jul 31 14:10:03 elk.roror.co.kr logstash[4463]: [2026-07-31T14:10:03,883][WARN ][logstash.filters.geoi>
lines 1-20/20 (END)...skipping...
```

수정된 설정을 적용하기 위해 Logstash 서비스를 재시작하고, Logstash 서비스가 오류 없이 정상 동작(active (running)) 상태로 전환되었는지 확인한다.

Rocky에서 작업

13. 로그 전송 통신 상태 재점검

```
root@roror:/home/roror# filebeat test output
logstash: 10.0.0.222:5044...
  connection...
    parse host... OK
    dns lookup... OK
    addresses: 10.0.0.222
    dial up... OK
  TLS... WARN secure connection disabled
  talk to server... OK
```

이전 방화벽(5044 포트) 허용 조치 및 Logstash 서비스 정상 구동을 통해 TCP 연결 및 서버 통신이 오류 없이 정상 연결되었음을 확인하였다.

14. Filebeat 실행

```
root@roror:/home/roror# systemctl enable filebeat
root@roror:/home/roror# systemctl restart filebeat
root@roror:/home/roror# systemctl status filebeat
● filebeat.service - Filebeat sends log files to Logstash or directly to Elasticsearch.
     Loaded: loaded (/usr/lib/systemd/system/filebeat.service; enabled; preset: disabled)
     Active: active (running) since Fri 2026-07-31 23:11:58 KST; 6s ago
 Invocation: 96a7327566174866da50440aa17712530
       Docs: https://www.elastic.co/beats/filebeat
   Main PID: 5672 (filebeat)
      Tasks: 8 (limit: 48523)
     Memory: 47.1M (peak: 47.8M)
        CPU: 62ms
     CGroup: /system.slice/filebeat.service
             └─5672 /usr/share/filebeat/bin/filebeat --environment systemd -c /etc/filebeat/filebeat.yml --path.home /usr/

Jul 31 23:11:59 roror.co.kr filebeat[5672]: {"log.level":"warn","@timestamp":"2026-07-31T23:11:59.006+0900","log.origin":{
Jul 31 23:11:59 roror.co.kr filebeat[5672]: {"log.level":"info","@timestamp":"2026-07-31T23:11:59.006+0900","log.logger":"
Jul 31 23:11:59 roror.co.kr filebeat[5672]: {"log.level":"info","@timestamp":"2026-07-31T23:11:59.006+0900","log.logger":"
Jul 31 23:11:59 roror.co.kr filebeat[5672]: {"log.level":"info","@timestamp":"2026-07-31T23:11:59.006+0900","log.logger":"
Jul 31 23:11:59 roror.co.kr filebeat[5672]: {"log.level":"info","@timestamp":"2026-07-31T23:11:59.006+0900","log.logger":"
Jul 31 23:11:59 roror.co.kr filebeat[5672]: {"log.level":"info","@timestamp":"2026-07-31T23:11:59.006+0900","log.logger":"
Jul 31 23:11:59 roror.co.kr filebeat[5672]: {"log.level":"info","@timestamp":"2026-07-31T23:11:59.006+0900","log.logger":"
Jul 31 23:11:59 roror.co.kr filebeat[5672]: {"log.level":"info","@timestamp":"2026-07-31T23:11:59.006+0900","log.logger":"
Jul 31 23:12:01 roror.co.kr filebeat[5672]: {"log.level":"info","@timestamp":"2026-07-31T23:12:01.992+0900","log.logger":"
```

Filebeat 서비스를 부팅 시 자동 시작되도록 등록하고, 변경된 설정 적용을 위해 서비스를 재시작하고, Filebeat 에이전트가 오류 없이 정상 구동(active (running)) 상태로 유지되는지 최종 확인한다.

15. SSH 실패 로그 발생

```
root@kali:/home/kali# ssh roror@10.0.0.200
Welcome
roror@10.0.0.200's password:
Permission denied, please try again.
roror@10.0.0.200's password:
Permission denied, please try again.
roror@10.0.0.200's password:
roror@10.0.0.200: Permission denied (publickey,gssapi-keyex,gssapi-with-mic,password).
```

연속 3회 잘못된 비밀번호를 입력하여 인증 실패 발생 상황을 만들고, 로그 수집 테스트를 위해 SSH 로그인 실패 로그 데이터를 생성한다.

16. Rocky에서 로그 확인

```
root@roror:/home/roror# tail -f /var/log/secure
Jul 31 23:40:27 roror sshd-session[5830]: pam_unix(sshd:session): session closed for user roror
Jul 31 23:40:33 roror unix_chkpwd[5889]: password check failed for user (roror)
Jul 31 23:40:33 roror sshd-session[5887]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser=
 rhost=10.0.0.133  user=roror
Jul 31 23:40:35 roror sshd-session[5887]: Failed password for roror from 10.0.0.133 port 41824 ssh2
Jul 31 23:40:38 roror unix_chkpwd[5890]: password check failed for user (roror)
Jul 31 23:40:40 roror sshd-session[5887]: Failed password for roror from 10.0.0.133 port 41824 ssh2
Jul 31 23:40:44 roror unix_chkpwd[5891]: password check failed for user (roror)
Jul 31 23:40:45 roror sshd-session[5887]: Failed password for roror from 10.0.0.133 port 41824 ssh2
Jul 31 23:40:46 roror sshd-session[5887]: Connection closed by authenticating user roror 10.0.0.133 port 41824 [preauth]
Jul 31 23:40:46 roror sshd-session[5887]: PAM 2 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=10
.0.0.133  user=roror
```

외부 접속 시도 시 발생한 Failed password for roror 같은 인증 실패 메시지가 /var/log/secure 파일에 즉시 기록되는 것을 통해 Filebeat의 로그 수집 대상 이벤트가 정상적으로 발생했음을 확인한다.

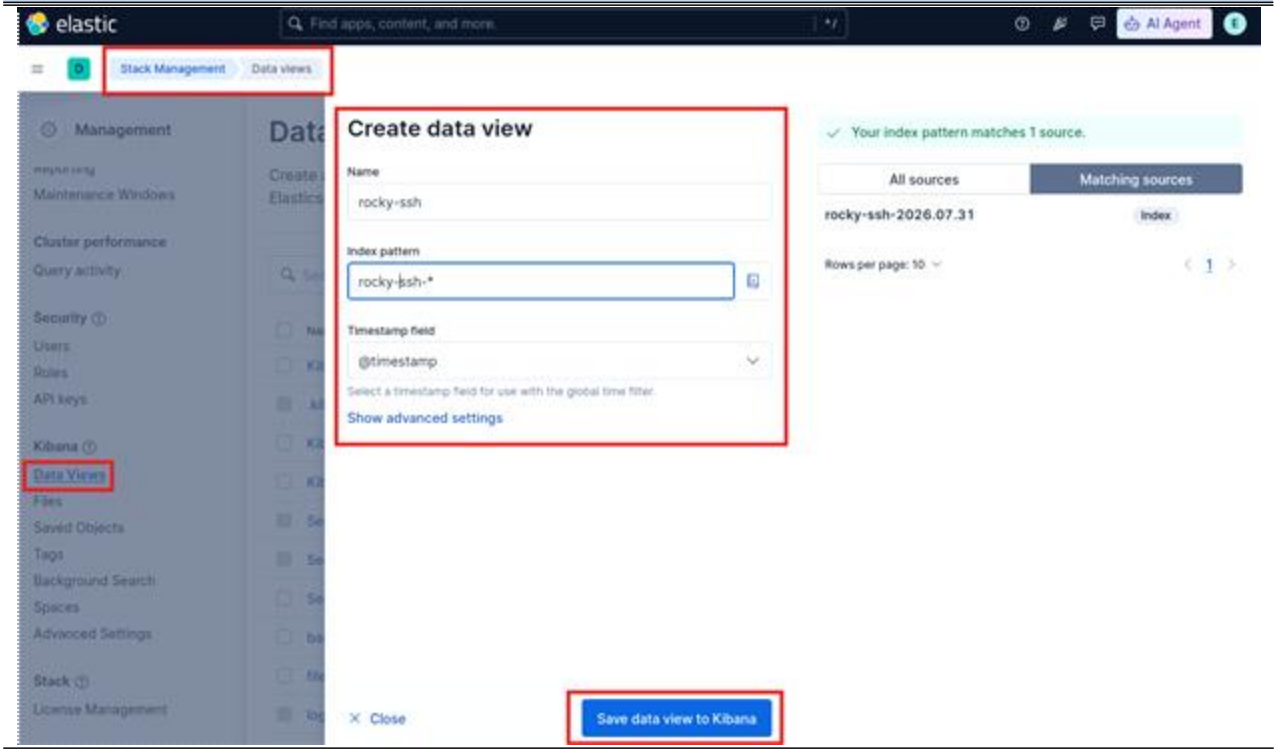
Ubuntu에서 작업

17. Elasticsearch 확인

```
root@elk:/etc/logstash/conf.d# curl -k -u elastic:qhdks12 \
https://elk.roror.co.kr:9200/_cat/indices?v | grep rocky
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100  5208    0  5208    0     0   356k      0 --:--:-- --:--:-- --:--:--  363k
green  open   rocky-ssh-2026.07.31                                zVevJHqtRnSn4Yj11DP8CA   1   1
          0    151.5kb         75.7kb       75.7kb
```

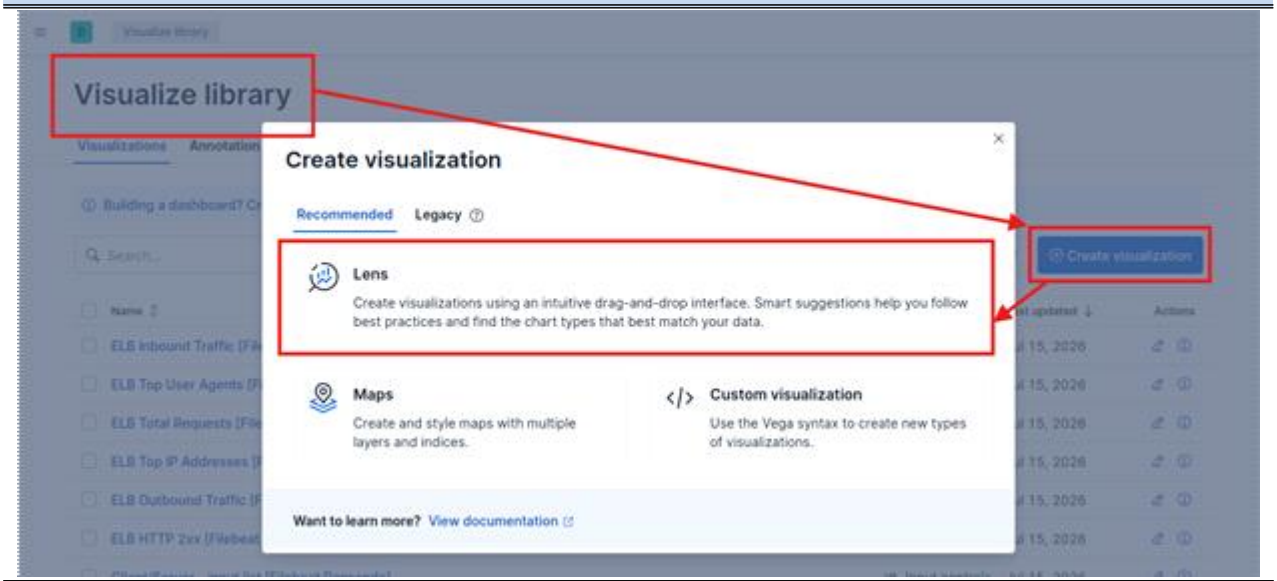
curl 명령을 통해 Elasticsearch API(/_cat/indices)로 인덱스 목록을 조회하고 rocky 키워드로 결과를 필터링하여 수집 및 파이프라인 처리를 거친 SSH 로그가 지정한 인덱스(rocky-ssh-2026.07.31)로 생성되어 정상적으로 저장 및 적재되었음을 최종 확인한다.

18. Data View 생성



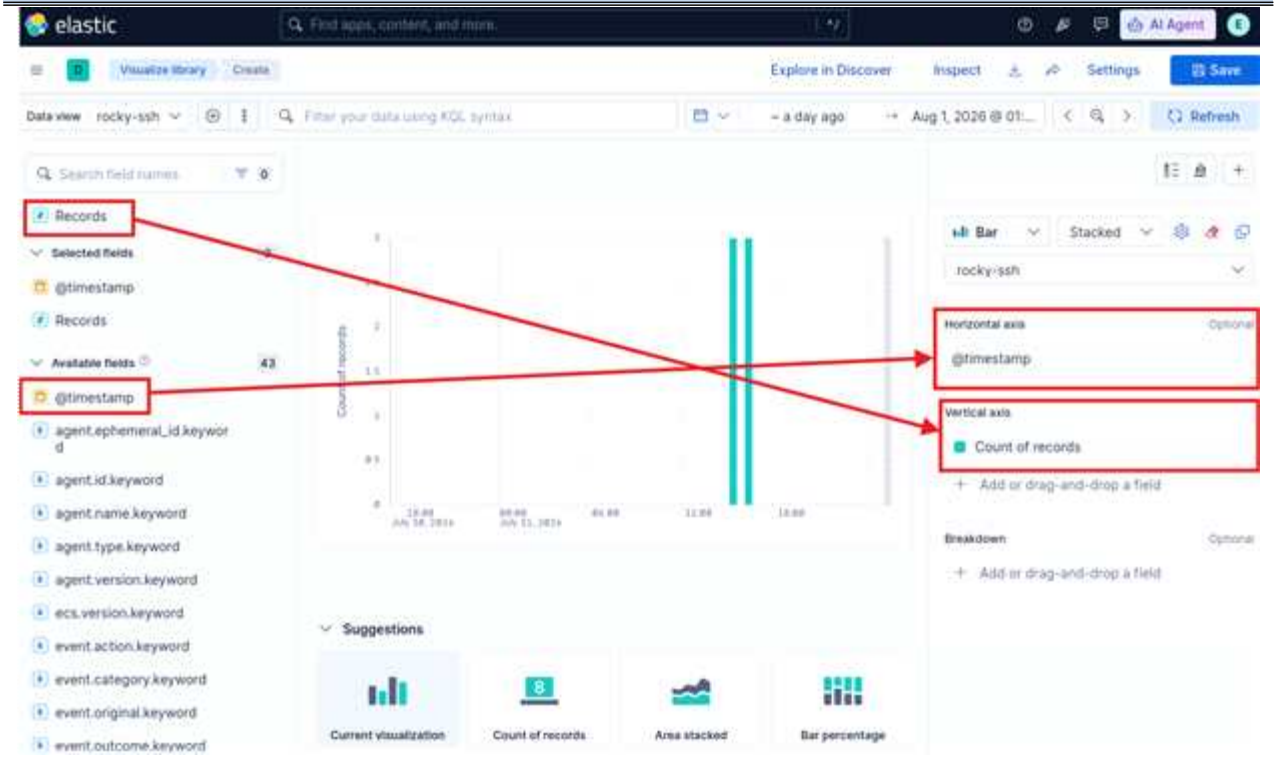
Name을 rocky-ssh, Index pattern을 rocky-ssh-*로 지정하고 Timestamp field를 @timestamp로 설정한 후 Save data view to Kibana 버튼을 클릭하여 시각화 및 탐색을 위한 데이터 뷰 구성을 완료한다.

19. 시각화 차트 생성



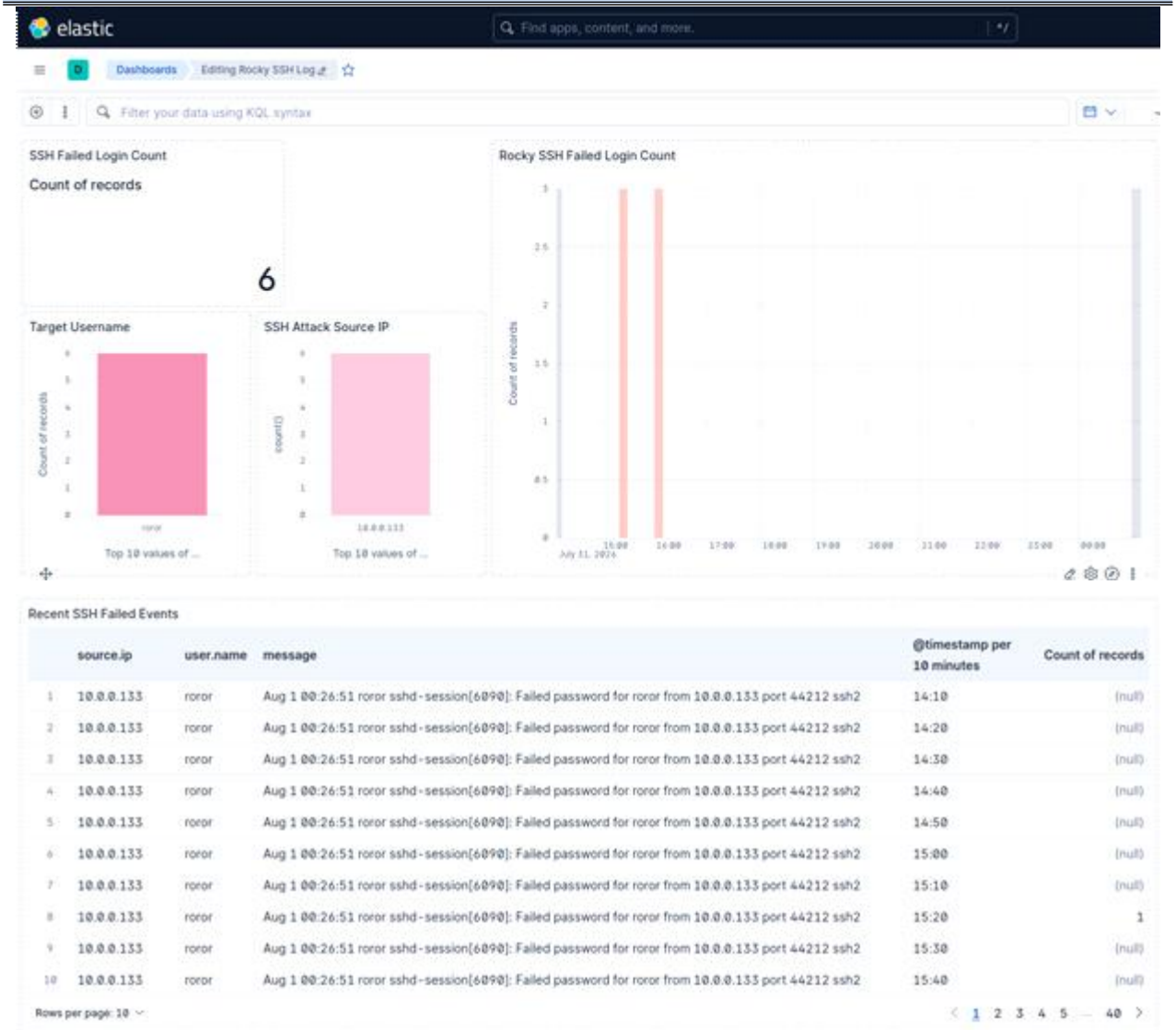
Visualize library로 이동하여 우측 상단의 Create visualization 버튼을 클릭하여 드래그 앤 드롭 방식을 지원하는 Lens 도구를 선택하여 시각화 차트 생성 화면으로 들어간다.

20. SSH 접속 실패 로그 막대 차트 생성



Data view를 rocky-ssh로 선택한 후, 좌측 필드 목록에서 @timestamp를 Horizontal axis(X축)로, Records를 Vertical axis(Y축)로 각각 지정하여 SSH 접속 실패 로그 발생 건수(Count of records)의 추이를 막대 차트(Bar chart) 형태로 시각화한다.

21. Dashboards 완성



SSH 인증 실패 총 건수(Metric), 공격 시도 계정 및 IP(Bar Chart), 시간대별 시도 추이(Line Chart), 상세 이벤트 내역(Data Table) 등 다양한 시각화 패널을 구성하여 대시보드 구축을 완료하였다.